

Information Security Policy

Version 5.0
August 2025

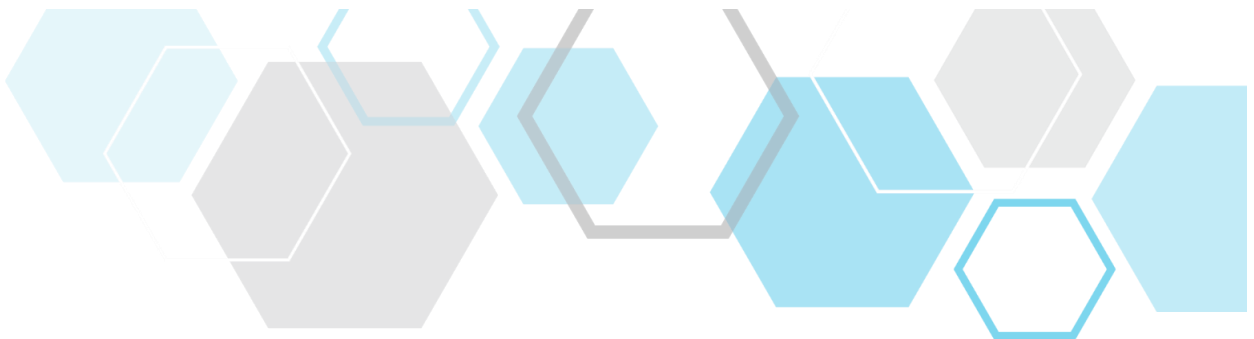


Table of Contents

Purpose.....	2
Overview	2
Application	3
Authority.....	3
Roles and responsibilities	3
Definitions	3
Advice on this policy	3
Policy Requirements	4
1. Organization of information security	4
2. Information security policies and standards	5
3. IT asset management.....	6
4. Access to information systems and devices.....	7
5. Physical and environmental security	7
6. Network and communications security	8
7. Operations security	9
8. Encryption	10
9. Information system procurement, development, and maintenance	11
10. Supply chain risk management.....	14
11. Information incident management.....	16
12. Business continuity management.....	16
13. Assurance and compliance	17
Revision history	18

Purpose

The Information Security Policy (ISP) outlines high-level requirements to ensure the information security practices of the B.C. government are reasonable, appropriate, and efficient. This ensures that personal and confidential information is protected in compliance with the security requirements of the [Freedom of Information and Protection of Privacy Act](#) and the [Information Management Act](#).

Overview

The ISP provides the foundation for the information security governance program, which includes standards, procedures, training and awareness material, all of which are used to protect government information and information systems. All employees need to be aware of their responsibilities to safeguard government information.

This policy supplements the B.C. government [Core Policy and Procedures Manual](#) and the [Appropriate Use Policy](#). It provides the framework for government organizations to establish local policies and procedures necessary for the protection of information and information assets for the B.C. government. This policy must be considered in conjunction with:

- [Core Policy Procedures Manual \(CPPM\)](#)
- [BC Public Service Agency - Human Resource Policies, including Standards of Conduct and Oath of Employment](#)
- [Appropriate Use Policy](#)
- [Information Incident Management Policy](#)

- [Managing Government Information Policy](#)
- [IM/IT Standards](#)
- Other corporate or ministry policies, standards, and strategic directions.

Application

This policy applies to all entities identified in the Core Policy and Procedures Manual [Chapter 1, section 1.2.4](#).

Authority

[Core Policy and Procedures Manual \(CPPM\)](#)

Roles and responsibilities

[Security roles and responsibilities](#)

Definitions

[Information Security Glossary](#)

Advice on this policy

For questions regarding this policy, contact:

Cybersecurity and Digital Trust Branch, Office of the Chief Information Officer
Ministry of Citizens' Services

Email: InfoSecAdvisoryServices@gov.bc.ca

Policy Requirements

1. Organization of information security

The OCIO and ministries must:

- 1.1. Provide executive leadership and support for information security by:
 - a. Implementing the information security policy to ensure secure delivery of government services.
 - b. Creating a management structure to coordinate the information security activities to support the policy.
 - c. Define, document, and communicate information security roles and responsibilities for information and information systems, including any designates or delegations, to ensure employees are informed of their roles and responsibilities.
- 1.2. Coordinate the implementation of information security activities across government to:
 - a. Maintain a robust security posture.
 - b. Resolve security issues effectively.
- 1.3. Maintain contacts with:
 - a. Local law enforcement authorities and emergency support organizations to facilitate coordination and timely response from outside authorities during information security incidents or investigations.
 - b. Security forums and professional associations, including the [Canadian Center for Cyber Security](#), to promote and expand employee

knowledge on information security industry trends, best practices, new technologies, and threats or vulnerabilities.

The OCIO (for enterprise systems) and ministries (for ministry systems) must:

- 1.4. Segregate activities and areas of responsibility to reduce opportunities for unauthorized or unintentional modification or misuse of information systems.
- 1.5. Identify and address information security risks throughout the lifecycle of an information system.
- 1.6. Conduct a formal review before a new or significantly modified information system or processing facility is approved to ensure adequate security controls are implemented for its secure operation.

2. Information security policies and standards

2.1. The Cybersecurity and Digital Trust branch (CDT) must:

- a. Direct and manage the development and review of the corporate Information Security Policy (ISP) and IM/IT security standards.
- b. Monitor and measure ISP implementation.

2.2. Ministries must comply with the ISP and IM/IT security standards.

Ministry-specific policies can have stronger requirements than the ISP or IM/IT security standards but cannot have weaker requirements.

The CDT (for ISP) and ministries (for ministry-specific information security policies) must:

- 2.3. Publish and communicate information security policies to all employees and relevant third parties.

2.4. Review information security policies and standards annually and update as needed based on changes in business needs,¹ risks, or technology.

2.5. Establish, issue, and monitor processes and practices that assist ministries in delivering secure services in compliance with the ISP and IM/IT security standards.

3. IT asset management

The OCIO and ministries must:

3.1. Maintain an inventory of government information systems and IT devices, including software and IM/IT agreements.

3.2. Validate the measures taken to protect information systems and devices as part of an enterprise risk management strategy. This includes maintaining, documenting, verifying, and valuing asset inventories on a regular basis.

3.3. Document the return of government IT assets in employee's possession when an employment is terminated.

3.4. Erase government information from devices and storage media (if no longer needed) in accordance with the government disposal process.

¹ Situations where business needs may require a policy review include:

- Legislative, regulatory, or policy changes.
- Closing investigation report on information security incidents.
- Renewal of third-party access agreements that involve major government programs or services.
- New or significantly revised industry, national, or international information security standards.
- External agency reports or identification of emerging trends related to information security.

3.5. Dispose of devices and storage media in secure manner appropriate to the sensitivity of the information on the device or storage media.

4. Access to information systems and devices

Ministries must:

4.1. Define, document, implement, communicate, and maintain procedures that ensure access to government information systems and devices are granted to individuals based on:

- a. Business requirements
- b. Principle of least privilege
- c. Need-to-know principle

4.2. Ensure that government information and devices are protected regardless of the type of access or physical location of employees.

4.3. Develop and communicate policies and processes specific to areas that govern teleworking and ensure that Telework Agreements are in place.

The OCIO and Ministries must:

4.4. Ensure controls are implemented to mitigate security risks associated with the use of mobile IT devices.

5. Physical and environmental security

Ministries, in collaboration with the Real Property Division (RPD) and Government Security Office (GSO), must:

5.1. Design, document, and implement security controls for a facility based on an assessment of security risks to the facility.

- 5.2. Review and test physical security and environmental control requirements, where appropriate.
- 5.3. Establish appropriate entry controls to restrict access to:
 - a. Secure areas.
 - b. Prevent unauthorized physical access to government information, systems, and IT assets.
- 5.4. Incorporate physical security controls to protect against natural disasters, malicious attacks, or accidents.
- 5.5. Protect government information and IT assets used outside of government facilities from unauthorized access, loss, theft, and damage.
- 5.6. Implement physical security controls for unattended government IT assets.
- 5.7. Require employees to secure unattended government IT assets and devices in their custody to prevent theft or unauthorized access to government information.

6. Network and communications security

- 6.1. The Government Chief Information Officer (GCIO) must provide direction and leadership on the implementation or significant modification of electronic messaging systems.
- 6.2. Ministries, in collaboration with the OCIO, must:
 - a. Before a new service delivery starts:
 - Document network security controls.
 - Ensure security features are implemented.

- b. Document, implement, and manage changes to network security controls and security management practices.
- c. Segregate services, information systems, and users based on the principle of least privilege, risk management, and business requirements.
- d. Implement network controls to prevent unauthorized access or bypassing of security controls.
- e. Ensure electronic messaging systems are:
 - Protected relative to the value and sensitivity of message content.
 - Approved for use by the GCIO.
- f. Ensure information transfers between government and external parties are protected using services approved for use by the GCIO.

7. Operations security

OCIO (for enterprise systems) and ministries (for ministry systems) must:

- 7.1. Ensure operating procedures and responsibilities for managing information systems and information processing facilities are authorized, documented, reviewed, maintained on a regular basis.
- 7.2. Plan, document, and implement change management processes to ensure changes to information systems and information processing facilities are authorized, applied correctly, and do not compromise the security of information and information systems.
- 7.3. Implement controls to prevent data loss.
- 7.4. Monitor and maintain information systems throughout their lifecycle.

- 7.5. Plan and manage resource capacity to maintain the availability of information systems.
- 7.6. Implement controls to segregate production information systems from non-production information systems.
- 7.7. Protect information systems from malware.
- 7.8. Implement and test backup controls to support efficient information systems recovery following a disaster.
- 7.9. Implement logging and monitoring controls for information systems to detect system errors, compromise, or unavailability.
- 7.10. Establish controls to protect log files from unauthorized modification, access, or disposal.
- 7.11. Enable synchronization of computer clocks to maintain the integrity of information system logs and keep reporting accurate.
- 7.12. Establish processes to identify, assess, and respond to vulnerabilities in information systems.
- 7.13. Manage information system compliance audits and implement controls to protect information systems and information throughout the audit process.

8. Encryption

- 8.1. The OCIO must:
 - a. Provide a framework and governance requirements for use of encryption and provision of encryption services.

- b. Set the corporate direction for the management (generation, storage, archival, distribution, revocation, and destruction) of encryption keys throughout their lifecycle.

8.2. Ministries and the OCIO must:

- a. Determine the need for information encryption controls during system design, based on business requirements, value, and information sensitivity.
- b. Select information encryption controls to provide the appropriate protection relative to information security classification level.

9. Information system procurement, development, and maintenance

9.1. The OCIO must direct and manage the development of security standards for the procurement, development, and maintenance of government information systems.

9.2. Ministries must:

- a. Comply with corporate information security standards, including the [Policy on the use of generative AI](#), when procuring, developing, and maintaining information systems.
- b. Ensure information security is designed into all architectural layers of information systems.
- c. Develop and maintain a roadmap and budget for the maintenance and upgrade of critical information systems to ensure they continue to meet government security requirements throughout their lifecycle.

- d. Develop and maintain a system security plan for each information system.
- e. Protect information in information systems throughout their lifecycle from unauthorized disclosure, modification, and fraudulent activity relative to the value and sensitivity of the information they store, process, or transmit.
- f. For card payment processing systems, ensure the 12 high-level requirements of the Payment Card Industry Data Security Standard (PCI DSS) are implemented.
- g. Develop, implement, and manage the processes and procedures necessary to ensure that information security risks and privacy requirements are considered throughout the systems development lifecycle.
- h. Require secure information system engineering principles to be applied to all information system (in-house and outsourced) engineering activities.
- i. Apply vulnerability scanning, security testing, and system acceptance processes relative to the value and sensitivity of the information system.
- j. Develop and maintain up-to-date disaster recovery plans for all information systems.
- k. Ensure sufficient resources and funding are allocated to complete the necessary information security tasks.

Electronic commerce information systems

The OCIO (for enterprise systems) and ministries (for ministry systems) must:

- 9.3. In addition to [9.2.d](#), protect information in electronic commerce information systems from contract dispute.
- 9.4. Before initiating or implementing changes to electronic commerce information systems:
 - a. Ensure information security risks related to electronic commerce are addressed.
 - b. Ensure user notification and acceptance of terms and conditions of use are compliant with government policies and standards.
 - c. Confirm the security controls to protect payment information meet PCI-DSS requirements.
- 9.5. Confirm the security certification and accreditation of the information system.
- 9.6. Develop and implement processes to maintain the information system's monetary content up-to-date.

Electronic documents

For systems that accept or submit electronic business documents, the OCIO (for enterprise systems) and ministries (for ministry systems) must:

- 9.7. Ensure the user's claimed identity is authenticated.
- 9.8. Determine an authorization process for approving content, distribution, or signing of key documents.
- 9.9. Identify and implement security controls to:

- a. Preserve the confidentiality and integrity of digital business documents (like contracts)
- b. Provide proof of dispatch and receipt of key documents.

Online transaction security

To preserve online transaction security in systems, the OCIO (for enterprise systems) and ministries (for ministry systems) must:

9.10. Implement security controls to prevent:

- a. Incomplete transmission
- b. Misrouting
- c. Repudiation of transaction
- d. Unauthorized message alteration, disclosure, duplication, and replay

9.11. Ensure the security controls:

- a. Validate and verify user credentials.
- b. Use digital signatures.
- c. Use encryption to protect data and information.
- d. Establish secure communication protocols.
- e. Place servers storing online transactions details in an appropriate network security segment.

10. Supply chain risk management

Supplier systems and services

The OCIO and ministries must:

- 10.1. Determine the information security classification and criticality of the information to identify and implement the necessary security controls before allowing third-party access to government information, information systems, or information processing facilities.
- 10.2. Identify, assess, mitigate, and manage associated risks related to using a supplier's information and technology service or supplier's access to or management of government information, information systems, and information processing facilities.
- 10.3. Ensure assessed risks, information security classification, and criticality requirements of government information and information systems involved are considered when changes to a supplier's agreement are being made.
- 10.4. Ensure suppliers meet government information security requirements.

Cloud services

The OCIO must:

- 10.5. Provide corporate direction and leadership on the secure use of cloud services.

Ministries must:

- 10.6. Consider existing cloud service offerings provided by the OCIO through corporate arrangements before procuring new cloud services.
- 10.7. Notify the GCIO before procuring cloud services not available through a corporate supply arrangement.
- 10.8. Ensure cloud services meet government security requirements.

11. Information incident management

Ministries must:

- 11.1. Establish ministry-specific information incident management policies and procedures complementary to [Information Incident Management Policy](#) (IIMP) to ensure quick, effective, and orderly response to information incidents within the ministry.
- 11.2. Conduct post-incident reviews and implement recommended actions to prevent future recurrences of the incident.

12. Business continuity management

Ministries must:

- 12.1. Establish, document, implement, and maintain processes, procedures, and controls to ensure the required level of information security for business continuity and disaster recovery during an adverse situation is met.
- 12.2. Conduct business impact assessments (BIAs) to help define business continuity and disaster recovery plans.
- 12.3. Ensure that vital records and critical information and systems are identified in business continuity plans.
- 12.4. Review business continuity and disaster recovery plans annually.
- 12.5. To ensure they are current, valid, functional and readily accessible during a business interruption, update business continuity and disaster recovery plans when either:
 - a. Legislative, business, or technology changes occur.

- b. Warranted by results from a business continuity and disaster recovery exercise.
- 12.6. Conduct business continuity and disaster recovery exercises:
 - a. On a regular schedule, based on the criticality of the business.
 - b. After an update to business continuity or disaster recovery plans.

13. Assurance and compliance

The Chief Information Security Officer (CISO) must:

- 13.1. Initiate an independent review of the overall government information security program on a regular basis.
- 13.2. In collaboration with ministries, report on each ministry's adherence to the information security policies and standards.

Ministries must:

- 13.3. Ensure legislative, regulatory, and security requirements for information systems are identified, documented, addressed, and maintained in policies and standards.
- 13.4. Regularly review information systems, business processes, and procedures to ensure compliance with security policies and standards.
- 13.5. Ensure contracts identify and document legislative, regulatory, and security requirements.

Document Version: 5.0
Effective Date: August 2006
Last Reviewed: August 2025

Revision history

Version	Revision Date	Author	Description of Revisions
5.0	April 2025	K. Petrosyan J. Hatherly S. Gopaldas Johnston	Template change, content updates from standards, plain language editing.
4.01	November 2021	K. Petrosyan/ S. Browning	Minor edits, links update.
4.0	September 2018	C. Brown	Complete rewrite of ISP V3.0